

ANALISI TECNICA MALWARE

Analisi statica e dinamica del campione notepad-classico.exe (VirusTotal / Sandbox)

1. Identificazione e Dati Generali del Campione

L'analisi è iniziata dall'eseguibile sospetto rinominato localmente "notepad-classico.exe". Come prima operazione di analisi statica è stato utilizzato il software HashMyFiles per estrarre l'impronta digitale (hash crittografico) del file, così da garantirne l'integrità e l'univocità durante l'indagine.

Eseguibile analizzato: notepad-classico.exe

Strumento di estrazione hash: HashMyFiles

Hash SHA-256 calcolato:

d2e6c9f9273663f3218bcd7cbfb3b6f599fbce7a4ba986f9bbff77e3603988f2

L'hash così ottenuto è stato successivamente interrogato sulla piattaforma di Threat Intelligence VirusTotal, restituendo le seguenti informazioni:

- **Nome file originale / mascherato:** NOTEPAD.EXE
- **Dimensione file:** 282,50 KB
- **Tasso di rilevamento (VirusTotal):** 58 / 72 vendor di sicurezza lo classificano come malevolo
- **Threat label popolare:** trojan.rozena/meterpreter
- **Classificazioni correlate:** Trojan:Win32/Meterpreter, Win32.Rozena.B
- **Categoria di minaccia / Family label:** trojan; famiglie rozena, meterpreter, swrort
- **Tag comportamentali:** peexe (eseguibile Windows a 32/64 bit); detect-debug-environment (rileva debugger/sandbox); long-sleeps (pause prolungate per eludere l'analisi dinamica automatizzata)

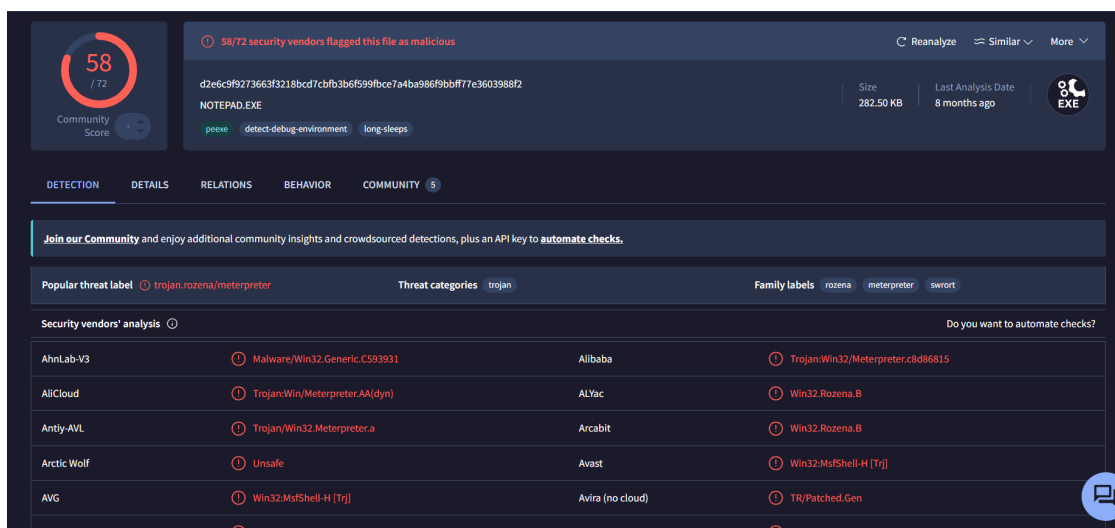


Figura 1 – VirusTotal, tab Detection: punteggio 58/72, threat label e behavior tag del campione NOTEPAD.EXE.

1.1 Attività Dinamica in Sandbox (Behavior Summary)

L'esecuzione controllata in sandbox (CAPE Sandbox, VirusTotal Jupyterbox, Zenbox, C2AE, CAPA, Microsoft Sysinternals) ha rilevato la seguente attività:

- **Network comms:** 2 richieste DNS e 7 connessioni IP dirette
- **Dropped files:** 8 file generati/rilasciati durante l'esecuzione
- **Mitre Signatures:** 3 Medium, 1 Low, 17 Info (totale 2 rilevamenti classificati come Malware, 1 come Trojan)
- **Behavior tags confermati:** detect-debug-environment, long-sleeps

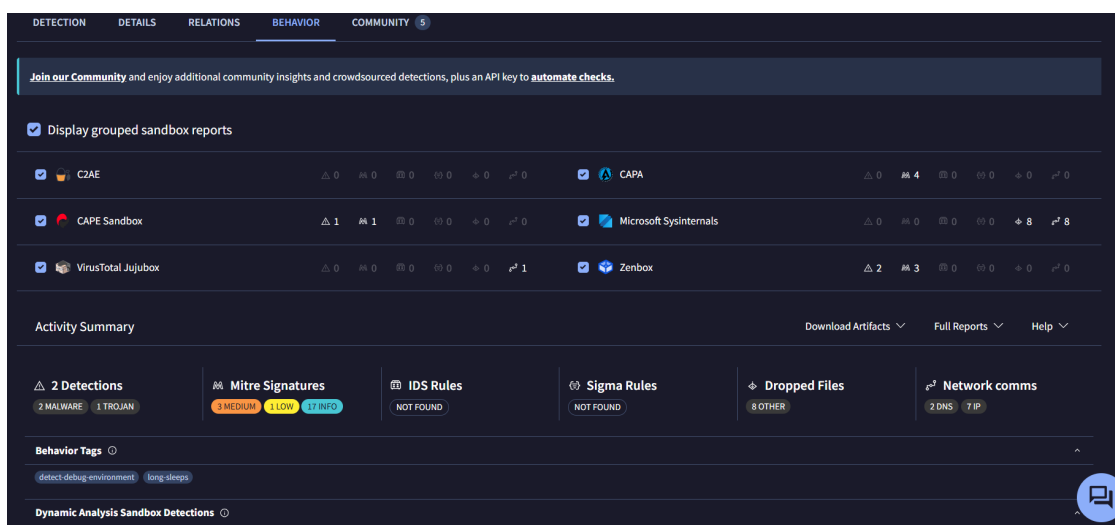


Figura 2 – VirusTotal, tab Behavior: motori sandbox utilizzati e Activity Summary (network comms, dropped files, Mitre signatures).

2. Librerie Importate (Imports) e Descrizione

Il file importa le seguenti librerie dinamiche (.dll) di sistema per interagire con il sistema operativo Windows:

1. **comdlg32.dll** (Common Dialog Box Library) – gestisce le finestre di dialogo standard di Windows (apri file, salva con nome, selezione colore/stampa). Spesso mantenuta per far sembrare il file un'applicazione legittima come il Blocco Note (NOTEPAD.EXE).
2. **SHELL32.dll** (Windows Shell API) – utilizzata per interagire con l'interfaccia della Shell di Windows, inclusa l'esecuzione di comandi esterni (ShellExecute), la gestione dei collegamenti (.lnk) e l'accesso alle cartelle di sistema.
3. **WINSPOOL.DRV** (Windows Print Spooler Driver) – gestisce i servizi e l'interfaccia di stampa. Può essere presente per simulare la legittimità di NOTEPAD.EXE o per abusare di componenti di sistema.
4. **COMCTL32.dll** (Common Controls Library) – fornisce i controlli grafici avanzati per le finestre (barre di stato, viste ad albero, tab), usata per la composizione grafica.
5. **msvcrt.dll** (Microsoft C Runtime Library) – libreria standard del linguaggio C/C++; gestisce allocazione di memoria (malloc, free), manipolazione di stringhe e operazioni matematiche.
6. **ADVAPI32.dll** (Advanced Windows Base API) – gestisce le funzionalità di sicurezza, il Registro

di Sistema e il Service Control Manager. Usata dal malware per garantire la persistenza al riavvio e per la verifica/elevazione dei privilegi.

7. **KERNEL32.dll** (Windows NT BASE API) – libreria principale di sistema; fornisce accesso alla memoria (VirtualAlloc, VirtualProtect), gestione di processi, thread e file. Essenziale per tecniche di Process Injection o Unpacking in memoria.
8. **GDI32.dll** (Graphical Device Interface) – gestisce grafica 2D, font e primitive grafiche; utilizzabile per rendering o per la cattura dello schermo (screen capture).
9. **USER32.dll** (User API) – gestisce la creazione delle finestre e l'intercettazione degli eventi di input (tastiera/mouse); nei malware è impiegata per keylogging o per nascondere le proprie finestre.

3. Sezioni del Malware (PE Sections)

Dall'analisi dell'header PE del file emergono 5 sezioni distinte, caratterizzate da specifici valori di indirizzamento, dimensione ed entropia:

Nome Sezione	Virtual Address	Virtual Size	Raw Size	Entropia	Note e Funzione
.text	4096	30536	30720	6.21	Codice eseguibile primario (Code Section). Entropia coerente con codice compilato standard, non compresso.
.data	36864	7080	2048	1.15	Variabili globali/statiche. Entropia molto bassa: dati altamente strutturati e ampio padding.
.rsrc	45056	36276	36352	5.42	Risorse dell'applicazione: 9 RT_ICON, 4 RT_STRING, 4 RT_DIALOG, 2 RT_ACCELERATOR.
.text (2ª)	81920	177836	178176	6.43	Seconda sezione .text: anomalia tipica di file packed o con stub di injection (es. Meterpreter). ~178 KB.
.idata	262144	4414	4608	5.44	Import Address Table (IAT): riferimenti alle funzioni esterne importate dalle DLL.

Sections

Name	Virtual Address	Virtual Size	Raw Size	Entropy	MD5	Chi2
.text	4096	30536	30720	6.21	17f1211e8b03c3f6f7f1199ecf63f60c	325067.25
.data	36864	7080	2048	1.15	3fd82fcc3cf0c0692e0e466248ee3fbf	402414.25
.rsrc	45056	36276	36352	5.42	1cd916daeba8c8a8fc51c2ca0e58aa8b	1277754.5
.text	81920	177836	178176	6.43	ab3871f91ae36088f8dde1e23261323a	1841049.5
.idata	262144	4414	4608	5.44	e947ddf995d196eb57e1da0366c76dab	65641.8

▼

Imports

+

comdlg32.dll

+

SHELL32.dll

+

WINSPOOL.DRV

+

COMCTL32.dll

+

msvcrt.dll

+

ADVAPI32.dll

+

KERNEL32.dll

+

GDI32.dll

+

USER32.dll

Contained Resources By Type

RT_ICON	9
RT_STRING	4
RT_DIALOG	4
RT_ACCELERATOR	2

Figura 3 – VirusTotal, tab Details: tabella delle sezioni PE e Import Table del campione.

4. Considerazione Finale sul Malware in Analisi

4.1 Identificazione Iniziale e Mascheramento (Spoofing)

Tramite l'uso preventivo di HashMyFiles sull'eseguibile notepad-classico.exe è stato possibile risalire al file originale NOTEPAD.EXE. Il file include risorse grafiche tipiche (icone RT_ICON, finestre di dialogo RT_DIALOG) e librerie di stampa/interfaccia come comdlg32.dll e WINSPOOL.DRV, integrate al solo scopo di impersonare il legittimo Blocco Note di Windows.

4.2 Natura del Payload (Meterpreter / Trojan)

La rilevazione condivisa da 58 vendor antivirus e la classificazione Trojan:Win32/Meterpreter indicano che il file è uno stager/payload generato da Metasploit (Meterpreter) oppure una backdoor della famiglia Rozena. La presenza di una seconda sezione .text di grandi dimensioni (178 KB) conferma che il codice malevolo è stato inserito/appeso al di sopra dell'eseguibile base legittimo.

4.3 Tecniche di Evasione e Command & Control (C2)

- **Evasione sandbox:** i flag detect-debug-environment e long-sleeps dimostrano che il malware posticipa l'esecuzione delle azioni dannose o verifica di trovarsi all'interno di una VM/sandbox per evitare l'analisi.
- **Connettività di rete:** l'attività dinamica evidenzia 7 connessioni IP dirette e 2 richieste DNS, necessarie al payload Meterpreter per stabilire una reverse shell verso il server C2 dell'attaccante.

4.4 Raccomandazione Operativa

Durante i test di laboratorio nella sandbox Kali Linux, l'uso delle regole iptables precedentemente configurate (blocco delle sottoreti private 10.0.0.0/8, 172.16.0.0/12, 192.168.0.0/16, con abilitazione del solo traffico IP verso Internet via MASQUERADE) garantisce l'isolamento completo dell'ambiente. Ciò consente al malware di tentare la connessione C2 o la risoluzione DNS ai fini dell'analisi del traffico, impedendogli categoricamente di infettare altri host o segmenti della rete locale.